Presentation

Start

1. `cd terraform && terraform apply`
2. Actions, **app**, **Run workflow**, `failure_mode = none` (about 7-10 min).
3. Check: `curl "$(terraform -chdir=terraform output -raw alb_url)/version"`

Shutdown

1. Wait for running deployments to finish.
2. `cd terraform && terraform destroy`
3. Do not merge changes in `terraform/` while the environment is down.

Preparation (day before)

For each branch below: create the branch from the current `main`, make the change, commit and push.

`demo/v1.1`: in `app/VERSION` change `1.0.0` to `1.1.0`.

`demo/critical-cve`: append the line `django==2.2` to `app/requirements.txt` (6 CRITICAL vulnerabilities, the `build` job stops at Trivy).

`demo/open-sg`: append to `terraform/network.tf` (the `trivy` check turns red):

```
resource "aws_security_group" "ssh" {
  name        = "ecs-supply-chain-ssh"
  description = "SSH access"
  vpc_id      = aws_vpc.main.id
}

resource "aws_vpc_security_group_ingress_rule" "ssh" {
  security_group_id = aws_security_group.ssh.id
  description       = "SSH from anywhere"
  cidr_ipv4         = "0.0.0.0/0"
  ip_protocol       = "tcp"
  from_port         = 22
  to_port           = 22
}
```

`demo/nat-gateway`: create `terraform/nat.tf` (cost +41.61 USD/month, `cost-gate` waits):

```
resource "aws_eip" "nat" {
  domain = "vpc"
}

resource "aws_nat_gateway" "demo" {
  allocation_id = aws_eip.nat.id
  subnet_id     = aws_subnet.public[0].id
}
```

Run

In a separate terminal for the whole time:

```
scripts/loadgen.sh "$(terraform -chdir=terraform output -raw alb_url)"
```

1. **Successful deployment:** open a PR from `demo/v1.1` to `main`. Merge after the checks are green (about 3-4 min). In `loadgen.sh` the version changes from 1.0.0 to 1.1.0 without errors. Show steps 2-4 while the checks and the deployment run.
2. **CRITICAL vulnerability:** open a PR from `demo/critical-cve`. After about 2 min the `build` job stops at the Trivy step, nothing is pushed to ECR. Close the PR.
3. **Infrastructure:**
   - open a PR from `demo/open-sg`. After about a minute the `trivy` check is red, merge blocked. Close the PR.
   - open a PR from `demo/nat-gateway`. After about 2 min a cost comment appears and `cost-gate` waits. Approve (Review deployments, Approve), do not merge, close the PR.
4. **Unsigned image:** `scripts/demo-unsigned.sh`. `cosign verify` rejects the image, ECR rejects the tag overwrite.
5. **Health check:** after the 1.1.0 deployment finishes, Run workflow with `failure_mode = health`. The new version gets no traffic, `loadgen.sh` shows no errors, report: STOPPED.
6. **Rollback on alarm:** Run workflow with `failure_mode = delayed`. Version `1.1.0-delayed` takes traffic, 500 errors after about 1.5 min, alarm, back to 1.1.0. Report: ROLLBACK. Show the alarm in CloudWatch and the Deployments tab in ECS.
7. Stop `loadgen.sh` (Ctrl+C) and show the summary.

Destroy the environment after the presentation.